

Pruebas de Autenticación y Usuarios

Actividad N°: 20 **Fecha:** 26/06/2026 **Horario:** 14:00 a 20:00 **Tutor Empresarial:** Miguel Vivanco **Pasante:** Gabriel

1. Objetivo del día

Diseñar y ejecutar un plan de pruebas funcionales sobre los módulos de autenticación, gestión de usuarios y control de acceso desarrollados durante la semana, verificando que se cumplen las reglas de negocio y los criterios de aceptación definidos en las historias de usuario (HU-01 y RF-09).

2. Alcance de la verificación

Las pruebas de este documento fueron verificadas mediante **revisión funcional del código implementado** (trazando cada regla contra su implementación real en los controladores). La ejecución end-to-end contra un ambiente vivo (servidor + MongoDB + interfaz) queda como actividad complementaria a realizar en conjunto con el tutor empresarial antes de pasar a producción.

3. Casos de prueba — Autenticación

ID	Caso de prueba	Pasos	Resultado esperado	Estado
PA-01	Login con credenciales válidas	POST <code>/api/auth/login</code> con usuario y contraseña correctos	200, devuelve <code>token</code> y datos de usuario	✓ Conforme
PA-02	Login con contraseña incorrecta	POST <code>/api/auth/login</code> con contraseña errónea	401 "Credenciales inválidas" (mismo mensaje que usuario inexistente)	✓ Conforme
PA-03	Login con usuario inexistente	POST <code>/api/auth/login</code> con usuario que no existe	401 "Credenciales inválidas"	✓ Conforme
PA-04	Login con usuario inactivo	Usuario con <code>activo: false</code> intenta login con contraseña correcta	401 "Credenciales inválidas"	✓ Conforme
PA-05	Acceso a ruta protegida sin token	GET <code>/api/tickets</code> sin header <code>Authorization</code>	401 "No token, autorización denegada"	✓ Conforme
PA-06	Acceso con token expirado/inválido	GET <code>/api/tickets</code> con token corrupto o vencido (>8h)	401 "Token no válido"	✓ Conforme
PA-07	Cambio de contraseña en primer acceso	POST <code>/api/auth/change-password</code> sin	200, <code>primerAcceso</code> pasa a <code>false</code>	✓ Conforme

ID	Caso de prueba	Pasos	Resultado esperado	Estado
		<code>currentPassword</code> , con <code>primerAcceso: true</code>		
PA-08	Cambio de contraseña normal sin indicar la actual	POST <code>/api/auth/change-password</code> con <code>primerAcceso: false</code> y sin <code>currentPassword</code>	400 "Contraseña actual es requerida"	✓ Conforme
PA-09	Cambio de contraseña con contraseña actual incorrecta	POST <code>/api/auth/change-password</code> con <code>currentPassword</code> erróneo	400 "Contraseña actual incorrecta"	✓ Conforme
PA-10	Contraseña nueva demasiado corta	<code>newPassword</code> con menos de 6 caracteres	400 "La nueva contraseña debe tener al menos 6 caracteres"	✓ Conforme
PA-11	Registro de auditoría en login/logout/cambio de contraseña	Ejecutar login, logout y cambio de contraseña	Se crean registros <code>AuditLog</code> con <code>tipo</code> correspondiente	✓ Conforme

4. Casos de prueba — Gestión de Usuarios

ID	Caso de prueba	Pasos	Resultado esperado	Estado
PU-01	Crear usuario Staff sin punto de trabajo	POST <code>/api/users</code> con <code>rol: staff</code> y sin <code>puntoTrabajo</code>	400 "Punto de trabajo es requerido para staff e impresor"	✓ Conforme
PU-02	Crear usuario con nombre de usuario duplicado	POST <code>/api/users</code> con <code>usuario</code> ya existente	400 "El usuario ya existe"	✓ Conforme
PU-03	Crear usuario Jefe (sin punto de trabajo)	POST <code>/api/users</code> con <code>rol: jefe</code> , sin <code>puntoTrabajo</code>	201, usuario creado con <code>puntoTrabajo: undefined</code>	✓ Conforme
PU-04	Contraseña por defecto en usuario nuevo	Crear cualquier usuario nuevo	Se asigna <code>DEFAULT_PASSWORD</code> y <code>primerAcceso: true</code>	✓ Conforme
PU-05	Un Staff intenta crear/editar/eliminar usuarios	Llamar <code>POST/PUT/DELETE /api/users</code> autenticado como Staff	403 "No tiene permisos para realizar esta acción"	✓ Conforme
PU-06	Jefe intenta desactivar su propia cuenta	PUT <code>/api/users/:id</code> (su propio id) con <code>activo: false</code>	400 "No puedes desactivar tu propia cuenta"	✓ Conforme
PU-07	Jefe intenta eliminar su propia cuenta	DELETE <code>/api/users/:id</code> (su propio id)	400 "No puedes eliminar tu propia cuenta"	✓ Conforme

ID	Caso de prueba	Pasos	Resultado esperado	Estado
PU-08	Listado de usuarios excluye inactivos	GET <code>/api/users</code> tras desactivar un usuario	La lista no incluye usuarios con <code>activo: false</code>	✓ Conforme

5. Casos de prueba — Roles y Permisos (incluye verificación del fix del día 19)

ID	Caso de prueba	Pasos	Resultado esperado	Estado
PR-01	Staff intenta ver dashboard/estadísticas	GET <code>/api/tickets/stats</code> autenticado como Staff	403 Forbidden	✓ Conforme
PR-02	Staff intenta ver auditoría	GET <code>/api/audit</code> autenticado como Staff	403 Forbidden	✓ Conforme
PR-03	Staff intenta reimprimir un ticket	POST <code>/api/tickets/:id/reprint</code> autenticado como Staff	403 Forbidden	✓ Conforme
PR-04	Staff intenta canje masivo directamente por API	POST <code>/api/tickets/bulk- canje</code> autenticado como Staff	403 Forbidden (antes del fix del día 19: 200 OK, indebido)	✓ Conforme — verificado tras la corrección
PR-05	Jefe ejecuta canje masivo	POST <code>/api/tickets/bulk- canje</code> autenticado como Jefe con lista de Ticket IDs	200, boletos actualizados vía <code>bulkWrite</code>	✓ Conforme
PR-06	Staff filtra tickets fuera de su punto de trabajo	GET <code>/api/tickets?</code> <code>puntoTrabajo=OTRO</code> autenticado como Staff	El filtro de <code>puntoTrabajo</code> enviado se ignora; solo ve su propio punto de trabajo	✓ Conforme

6. Hallazgos de esta ronda de pruebas

- **PR-04** confirma de forma concreta que la corrección aplicada el día 19 (Semana 4) cierra efectivamente la brecha detectada en la revisión de diseño de la Semana 3: antes del cambio, un Staff podía ejecutar canje masivo llamando directamente a la API aunque la interfaz no se lo mostrara.
- No se identificaron nuevos hallazgos de seguridad en autenticación o gestión de usuarios durante esta ronda.

7. Conclusiones del día

El módulo de autenticación, gestión de usuarios y control de acceso cumple con las reglas de negocio definidas, incluyendo la corrección de permisos aplicada esta misma semana. Se recomienda complementar

esta verificación con una ejecución en vivo (Postman/interfaz real) antes del cierre del proyecto, como parte de la etapa de integración y pruebas (Semana 7).

Observaciones: Pruebas verificadas por inspección funcional del código; pendiente ejecución en vivo en ambiente de pruebas.